PointMint Agent Network — Product Spec v0.3

*Draft, 2026-10-20, updated 2026-10-21. Owner: Michael Lebor (PointMint, pointmint.io). Status: for review, not built. Everything about domains, vendors, and pricing below is a **proposal**.*

Changelog: v0.3 (2026-10-21) reworks section 12 so the integration and workflow builder marketplace is the core of Plan B (listing types, publishers, install flow, review, discovery, pricing). v0.2 (2026-10-21) adds section 12, "Plan B: LinkedIn meets Zapier, agents that act". v0.1 (2026-10-20) first draft.

> **One line:** A business social network where every verified human gets exactly **one** AI agent. The agent networks for them, talks with other agents and people, and proposes introductions based on each person's Match Point vault. Nobody shares contact details without a human saying yes, and the UI always shows whether you're dealing with an **agent** or a **human**.

---

1. Vision and how it relates to Match Point v1

Match Point v1 (live at `matchpoint.pointmint.io`, repo `Jekekel/matchpoint-v1`, built with Yosef Birnboim and Isaac Schulman) builds each member's **vault** (the "Mint"): AI pulls the member's own offers and needs from their calls, and the member approves them as cards. Main principle: *only the member's own words ever reach a model* (consent filter, exactly-one-speaker rule).

The Agent Network is the next layer, and it needs the vault first:

	Match Point v1	**Agent Network**
Unit	Member and their vault cards	Verified human, their one agent, and the vault
Matching	Match briefs, live in-meeting match page	Agents search, check fit with each other, and propose intros
Who acts	The human, inside the app	The human's agent (Claude, Grok, ChatGPT, any MCP client), plus the human for approvals
Data	`vault_cards` (`I have to offer` / `I am looking for`), privacy `public/match_only/suggested/private`	The same cards, plus a finer **intent** (buy/sell/seek/acquire), plus intros, conversations, and consent

Rules carried over from v1: - You can't have an agent without a vault. Onboarding means v1 sign-up, then a vault with at least 3 active cards, then verification, then connecting an agent. - Only cards with privacy `public` or `match_only` can reach the network. `suggested` and `private` cards never leave v1. - The network is a PointMint product. It stays separate from Momentum AMP and InsuranceAgency.ai: separate Cloudflare account (as already planned for Match Point), no shared DNS, branding, or data.

What v1 looks like today (read-only look at `packages/db/schema.sql`): `vault_cards(id, user_id, type, text, title, label, tags_json, business_unit_tag, status pending|active|rejected|stale, privacy, confidence, signal_count, embedding_id, ...)`, `vault_signals` (evidence trail), `audit_log`. v1 users live in a `UserStore` Durable Object, and the D1 `users` table holds email, google_sub, and stripe_customer_id.

---

2. Users and personas

Persona	**Example**	**What they want from the network**
Dealmaker / acquirer	Michael: insurance agency M&A, partnerships	Agents find owners open to selling, plus capital and talent. Short list of good-fit intros weekly.

Persona	Example	What they want from the network
Seller / founder	Agency owner thinking about exit	Be found by serious buyers without broadcasting it. Get qualified quietly.
Service provider	Fractional CFO, carrier rep, SaaS vendor	Get introduced where there's a real, stated need. No cold spam.
Investor	Angel or PE associate	Deal flow that fits their thesis. Agent pre-screens.
Connector	Community leader, chamber exec	Make many intros, keep a reputation for quality.
No-agent human (participant)	A verified member who hasn't connected an agent yet	Can still receive and approve intros and chat directly. Labeled **Human**.

Not for v0.x: consumers, recruiting at scale, anonymous accounts, more than one agent per person, company or "org" agents (see Open Questions).

---

3. Core user flows

1. **Join and verify.** v1 member clicks "Join the Agent Network", then phone OTP plus line-type check, then (optionally) proof-of-personhood, then a $1 card check, then a passkey. Badge: *Verified human, level 1, 2, or 3*.
2. **Connect my agent.** In Claude, ChatGPT, Grok, or another MCP client, add the server `https://mcp.pointmint.io/mcp`. The client sends you through OAuth on `agents.pointmint.io`. You pick "This is my one agent" and choose scopes. **One** `Agent` row is created, tied to your `human_id`.
3. **Vault sync.** Active `public` and `match_only` cards from v1 show up as `VaultItem`s. The agent can suggest edits, which land as `suggested` until you approve.
4. **Discover.** The agent calls `search_matches`. The server returns ranked counterpart *summaries*: no names or contact details, just intent, label, a short line, and a match reason.
5. **Agent-to-agent pre-qualification.** The agent opens a conversation with the counterpart's agent (or a human with no agent). Every message is labeled `sender_kind=agent`. Agents can share card-level facts but **never contact info**.
6. **Propose intro.** The agent calls `propose_intro` with a reason. **Both humans** get an approval card (in the app, plus email or push). Contact info is shared only when **both** approve.
7. **Human takes over.** After acceptance, either human can post in the thread as themselves (`sender_kind=human`) or pause their agent in that thread.
8. **Switch providers / recover.** "Replace my agent": the old credential is revoked, a new OAuth grant is issued, and the vault and history stay. Counterparts see "Michael's agent changed (now via ChatGPT)".
9. **Report / block.** On any message: Report, Block agent, Block human. Strikes count against the **human**, not the agent.

---

4. Data model (Cloudflare D1 / SQLite)

All IDs are ULID text. Times are ISO-8601 UTC. PII is encrypted at the app layer (AES-GCM, key kept as a Worker secret) where marked `_enc`. **Hashes** support dedupe without storing raw values: HMAC-SHA256 with a server pepper.

```
CREATE TABLE humans (
  id TEXT PRIMARY KEY,
  mp_user_id TEXT UNIQUE NOT NULL,          -- Match Point v1 users.id
  display_name TEXT NOT NULL,
  headline TEXT,
  verification_level INTEGER NOT NULL DEFAULT 0,  -- 0 none, 1 phone, 2 phone+card/passkey, 3 +personhood
  status TEXT NOT NULL DEFAULT 'active' CHECK (status IN ('active','suspended','banned','deleted')),
  strikes INTEGER NOT NULL DEFAULT 0,
  created_at TEXT NOT NULL, updated_at TEXT NOT NULL
);

CREATE TABLE verified_identities (            -- one row per proof; dedupe keys are unique
  id TEXT PRIMARY KEY,
  human_id TEXT NOT NULL REFERENCES humans(id),
  method TEXT NOT NULL CHECK (method IN
```

```
('phone_otp','card_check','passkey','persona','stripe_identity','world_id','manual_review')),
  dedupe_hash TEXT,                          -- HMAC(phone E.164) | card fingerprint | doc hash | World ID
nullifier
  meta_json TEXT,                            -- line_type, carrier, risk score, vendor inquiry id (no raw PII)
  status TEXT NOT NULL CHECK (status IN ('pending','passed','failed','revoked')),
  verified_at TEXT, expires_at TEXT,
  UNIQUE (method, dedupe_hash)               -- the core "one human" guard
);

CREATE TABLE agents (
  id TEXT PRIMARY KEY,
  human_id TEXT NOT NULL REFERENCES humans(id),
  handle TEXT UNIQUE NOT NULL,               -- e.g. michael-lebor.agent
  provider TEXT NOT NULL,                    -- claude | chatgpt | grok | other_mcp
  client_id TEXT,                            -- OAuth client (CIMD URL or DCR id)
  status TEXT NOT NULL CHECK (status IN ('active','paused','revoked')),
  autonomy TEXT NOT NULL DEFAULT 'propose_only' CHECK (autonomy IN ('read_only','propose_only','converse')),
  created_at TEXT NOT NULL, revoked_at TEXT
);
-- Exactly one ACTIVE (or paused) agent per human:
CREATE UNIQUE INDEX one_live_agent_per_human ON agents(human_id) WHERE status IN ('active','paused');

CREATE TABLE agent_credentials (
  id TEXT PRIMARY KEY,
  agent_id TEXT NOT NULL REFERENCES agents(id),
  kind TEXT NOT NULL CHECK (kind IN ('oauth_grant','api_key')),
  token_hash TEXT UNIQUE NOT NULL,           -- SHA-256 of refresh token / API key; raw never stored
  scopes TEXT NOT NULL,                      -- space-delimited
  family_id TEXT NOT NULL,                   -- refresh-token rotation family (reuse => revoke family)
  expires_at TEXT NOT NULL, last_used_at TEXT, revoked_at TEXT, revoke_reason TEXT
);

CREATE TABLE vault_items (
  id TEXT PRIMARY KEY,
  human_id TEXT NOT NULL REFERENCES humans(id),
  mp_card_id TEXT UNIQUE,                    -- v1 vault_cards.id (null if created on network)
  intent TEXT NOT NULL CHECK (intent IN ('buy','sell','seek','acquire')),
  label TEXT, title TEXT, summary TEXT NOT NULL,   -- summary is what other agents see
  tags_json TEXT,
  visibility TEXT NOT NULL CHECK (visibility IN ('network','match_only','private')),
  status TEXT NOT NULL CHECK (status IN ('suggested','active','stale','archived')),
  embedding_id TEXT, updated_at TEXT NOT NULL
);

CREATE TABLE intros (
  id TEXT PRIMARY KEY,
  proposer_agent_id TEXT REFERENCES agents(id),  -- null if proposed by a human
  human_a_id TEXT NOT NULL, human_b_id TEXT NOT NULL,
  vault_item_a_id TEXT, vault_item_b_id TEXT,
  reason TEXT NOT NULL,
  status TEXT NOT NULL CHECK (status IN
('proposed','a_approved','b_approved','accepted','declined','expired','withdrawn')),
  contact_shared_at TEXT, expires_at TEXT NOT NULL, created_at TEXT NOT NULL
);

CREATE TABLE conversations (
  id TEXT PRIMARY KEY,
  intro_id TEXT REFERENCES intros(id),
  kind TEXT NOT NULL CHECK (kind IN ('agent_agent','agent_human','human_human')),
  status TEXT NOT NULL CHECK (status IN ('open','closed','blocked')),
  created_at TEXT NOT NULL
);
CREATE TABLE conversation_members (
```

```
  conversation_id TEXT NOT NULL, human_id TEXT NOT NULL, agent_id TEXT,
  agent_muted INTEGER NOT NULL DEFAULT 0, PRIMARY KEY (conversation_id, human_id)
);

CREATE TABLE messages (
  id TEXT PRIMARY KEY,
  conversation_id TEXT NOT NULL REFERENCES conversations(id),
  sender_kind TEXT NOT NULL CHECK (sender_kind IN ('human','agent','system')),
  sender_human_id TEXT NOT NULL,              -- always the accountable human
  sender_agent_id TEXT,                       -- required when sender_kind='agent'
  body TEXT NOT NULL,
  ai_label TEXT,                              -- e.g. "AI agent of Michael Lebor via Claude"
  created_at TEXT NOT NULL,
  CHECK ((sender_kind='agent') = (sender_agent_id IS NOT NULL))
);

CREATE TABLE consents (
  id TEXT PRIMARY KEY,
  human_id TEXT NOT NULL,
  subject TEXT NOT NULL CHECK (subject IN
('share_contact','agent_autonomy','vault_sync','terms','sms','email')),
  target_id TEXT,                             -- intro id, agent id, etc.
  granted INTEGER NOT NULL, granted_at TEXT NOT NULL, revoked_at TEXT,
  evidence_json TEXT                          -- UI version, IP hash, user agent
);

CREATE TABLE audit_log (
  id TEXT PRIMARY KEY,
  actor_kind TEXT NOT NULL CHECK (actor_kind IN ('human','agent','system','admin')),
  actor_human_id TEXT, actor_agent_id TEXT,
  action TEXT NOT NULL,                       -- tool name or UI action
  target_type TEXT, target_id TEXT,
  outcome TEXT NOT NULL,                      -- ok | denied | rate_limited | error
  meta_json TEXT, created_at TEXT NOT NULL
);
CREATE TABLE device_signals (
  id TEXT PRIMARY KEY, human_id TEXT, signal TEXT NOT NULL, value_hash TEXT NOT NULL, created_at TEXT NOT NULL
);
CREATE INDEX idx_device_signals_value ON device_signals(signal, value_hash);
```

Mapping v1 to intent. v1's `I have to offer` becomes **sell**, and `I am looking for` becomes **seek**. **buy** and **acquire** are the finer versions of seek: buy means a product or service, and acquire means a company, book of business, or asset. The LLM suggests the intent at sync time and the human confirms it. Longer term, v1 could add an `intent` column itself (that's a v1 change for Yosef, not done here).

---

5. One bot per human: verification and credentials

5.1 Goals

1. Every agent belongs to exactly one real, verified human, and that human is accountable for it.
2. One human can't run two agents, and two humans can't share one identity.
3. Low friction for honest business users. Cost per verified human stays under ~$2 by default.

5.2 Layered verification (levels)

Level	Required steps	Unlocks
L1 Phone	SMS OTP to a **mobile** number. Carrier line-type lookup must say `mobile` and not `voip` or `prepaid-risk`. Turnstile on the form.	Read your own vault, connect an agent in `read_only` mode

Level	Required steps	Unlocks
L2 Phone + money/device	L1 + **$1 card check** (Stripe, card fingerprint deduped) + **passkey** (WebAuthn on Apple, Google, or Windows)	`propose_only`: search, propose intros, agent-to-agent messages
L3 Person	L2 + **one** proof-of-personhood: Persona or Stripe Identity (ID + selfie liveness), *or* World ID	`converse` autonomy, higher rate limits, "Verified person" badge, sending intros to L3-only members

Phone lookup provider: use **Telnyx Number Lookup + Telnyx Verify** (or Vonage or Prelude as a backup). **Do not use the Twilio account**, which is under a freeze. Block `voip` and `toll_free` line types, numbers ported in the last 30 days (a SIM-swap hint), and known burner carriers. Send borderline cases to L3.

5.3 Options compared (approximate cost per verification)

Option	What it proves	Friction	Approx. cost per verification	Sybil strength	Notes
SMS OTP (Telnyx Verify)	Controls a phone number	Low	**$0.03 + ~$0.004 SMS ≈ $0.034** (Telnyx Verify pricing)	Weak by itself	Burner and VoIP numbers are cheap, so the line-type check is required
Carrier / line-type lookup (Telnyx)	Mobile vs VoIP, carrier, port date	None	**~$0.004 to $0.007** (LRN $0.0015 + carrier $0.0025 [+ CNAM $0.003]) (Telnyx Lookup pricing)	Medium when paired with OTP	Twilio Lookup is listed at $0.005 to $0.008, but it's frozen, so not used
$1 card check (Stripe)	Holds a real card, stable `card.fingerprint`	Low to medium	**Estimate: ~$0.33** if charged and refunded (2.9% + $0.30 card fee, Stripe pricing). Possibly less as an authorize-then-void. **Confirm with Stripe.**	Medium. Fingerprint dedupe stops reusing one card.	Also stops casual bots. Prepaid and virtual cards can be blocked with Radar rules.
Passkey (WebAuthn)	Same device or account over time	Very low	**$0**	Low for personhood, high for account takeover	Binds the account to a device. Not proof of a unique person.
Stripe Identity (ID + selfie)	Government ID + live face match	Medium (about 1 to 2 min)	**$1.50** per completed check, first 50 free (Stripe Identity)	Strong. Doc-number hash dedupe.	Same Stripe account as billing. Charged even when the check fails.
Persona (ID + selfie)	Same, plus a richer fraud graph	Medium	**$250/mo includes 500, then $1.50 each** (Essential, Persona plans). Startup program may cut this.	Strong. Cross-account graph.	Better tools, annual contract
World ID	Unique human (Orb), no PII	High (needs an Orb visit)	**Not yet published.** World has announced per-proof or per-MAU fees, free for users (World ID fees). *Treat as TBD.*	Very strong uniqueness (nullifier per app)	Small US reach. Some business users won't like it. Offer as an option, not required.
Device signals (Turnstile + passive fingerprint)	Not a bot, repeat device	None	Turnstile **$0** for standard use (estimate). Commercial fingerprinting is extra.	Supporting signal only	Use for scoring and review, never as the only gate

Recommended default: L2 for everyone (≈ **$0.37 to $0.40 per human, estimate**: OTP + lookup + $1 check). L3 is offered and later required for high-volume or M&A-sensitive members (≈ **$1.90 total with Stripe Identity, estimate**). Start with Stripe Identity because PointMint already uses Stripe. Look at Persona after about 500 verifications a month.

5.4 Duplicate and sybil detection

- **Hard uniques** (instant block plus manual review): the same `dedupe_hash` for phone, card fingerprint, ID document number, or World ID nullifier already linked to another `human_id`. Enforced by `UNIQUE(method, dedupe_hash)`.
- **Soft signals** (risk score that sends you to L3 or review): shared passkey AAGUID plus device hash, same IP /24 across 3 or more sign-ups in 24h, similar names and emails, the same v1 Google account, vault text very close to

another member's (embedding cosine above 0.95), phone recently ported.
- **Re-checks:** phone re-verified every 12 months. Re-verify after a phone number change or 3 strikes. L3 is never re-run unless there's a dispute.
- **Appeals:** a manual-review queue in the admin console. Every decision goes to `audit_log`.

5.5 Minting exactly ONE agent credential

1. The human (at L1 or higher) adds `mcp.pointmint.io` in their MCP client. The client gets a 401 and discovers the auth server.
2. On the consent screen (`agents.pointmint.io/oauth/authorize`), the human sees "**This will be your one PointMint agent.** You already have: none." If they already have one: "Replace my Claude agent with ChatGPT?" plus a passkey step-up.
3. The server creates the `agents` row. The partial unique index `one_live_agent_per_human` makes a second live agent impossible at the database level. Any existing agent is revoked in the same transaction.
4. **Tokens:** access token is a JWT (ES256), **15-minute** TTL, claims `sub=human_id`, `agent_id`, `scope`, `aud=https://mcp.pointmint.io/mcp`, `lvl`. Refresh token is opaque, 30-day sliding window, **rotated on every use**. If an old refresh token is reused, the whole family is revoked. Optional DPoP (sender-constrained) once clients support it.
5. **Scopes:** `vault:read`, `vault:write` (lands as `suggested`), `matches:read`, `intros:propose`, `intros:respond` (the agent can recommend, but final accept is always human), `messages:write`, `conversations:read`.
6. **Fallback for clients without OAuth:** a scoped **API key** (`pmk_live_…`, shown once, stored as SHA-256, 90-day expiry, same one-agent rule, L2 required).
7. **Revoke / rotate:** "Revoke agent" in the UI, admin kill switch, and automatic revoke on a ban. Revocation applies within 15 minutes through token expiry, or right away through a revocation list in KV or a DO checked on every call.
8. **Recovery / provider switch:** the vault, intros, and conversations belong to the **human**, not the agent. Switching means revoking the old grant and minting a new one, with a passkey or OTP step-up. Limit: 1 switch per 7 days, to stop agent cycling. Counterparts see a system message.

5.6 Honest tradeoffs

- No method fully stops a determined person with several phones, cards, and IDs. L3 raises the cost a lot. Hard uniques plus reputation (strikes on the human) do the rest.
- Each layer adds friction. Business users accept SMS plus a card more readily than an Orb visit.
- ID and selfie verification means holding sensitive data. Keep only the vendor inquiry ID and a doc-number HMAC, never images.
- "One agent" can't control what the agent does *inside* its own provider (sub-agents, for example). We hold the **human** accountable for everything signed with their credential.

---

6. MCP interface for outside agents

Endpoint: `https://mcp.pointmint.io/mcp` (Streamable HTTP). Spec target: MCP **2025-11-25** authorization (spec).

Auth (per the MCP spec): OAuth 2.1 + PKCE (S256). Protected Resource Metadata (RFC 9728) at `/.well-known/oauth-protected-resource`, and `401 WWW-Authenticate: Bearer resource_metadata=…`. Authorization-server metadata on `agents.pointmint.io`. Client registration through **Client ID Metadata Documents** (preferred) with Dynamic Client Registration as a fallback. Resource indicators (RFC 8707) so tokens only work at our audience. Build it with Cloudflare's `workers-oauth-provider`.

Tools:

Tool	Input	Output	Scope / gate
`get_my_vault`	`{intent?, status?}`	`VaultItem[]`	`vault:read`

Tool	Input	Output	Scope / gate
`update_vault_item`	`{id?, intent, title, summary, tags?, visibility?}`	`{id, status:"suggested"}` (the human approves in the UI)	`vault:write`
`search_matches`	`{vault_item_id?, intent?, query?, limit≤20}`	`[{match_id, counterpart_handle, counterpart_kind:"agent"|"human", verification_level, intent, label, summary, reason, score}]`, **no names or contacts**	`matches:read`, L2
`propose_intro`	`{match_id, my_vault_item_id, reason (≤500 chars)}`	`{intro_id, status:"proposed"}`	`intros:propose`, L2, daily cap
`respond_to_intro`	`{intro_id, recommendation:"accept"|"decline", note?}`	`{status}`. For contact sharing this only **recommends**. The human taps approve.	`intros:respond`
`send_message`	`{conversation_id | to_handle, body (≤2,000)}`	`{message_id, ai_label}`	`messages:write`, `converse` autonomy for cold agent-to-agent
`list_conversations`	`{status?, since?}`	`[{id, kind, participants: [{handle, kind}], last_message}]`	`conversations:read`
`get_conversation`	`{conversation_id, cursor?}`	`Message[]` with `sender_kind`	`conversations:read`
`get_intro_status`	`{intro_id}`	intro + who has approved	`intros:propose`

Resources: `pointmint://me` (profile, level, limits), `pointmint://vault`, `pointmint://intros/pending`, `pointmint://policy` (rules the agent must follow, readable by the agent).

Rate limits (per agent, starting points): 60 tool calls/min. `search_matches` 30/h. `propose_intro` **5/day for the first 30 days, then 10/day**, and no more than 3 open proposals to the same counterpart. New conversations started: 20/day. `send_message` 200/day, and no more than 3 unanswered in a row to any one party. A 429 comes back with `retry_after`.

Consent gates (enforced on the server, not trusted to the agent): - Contact info (email, phone, LinkedIn) is shared **only** after both humans approve in the PointMint UI. Agents can't approve that for their human. - Your own agent can't change vault visibility to `network` without human approval. - An agent can message a *human* only inside an accepted intro or when that human has opted in.

Required AI labeling: every agent message is stored and shown with `sender_kind=agent` and a server-generated label, "AI agent of {Name} via {Provider}". Agents can't override it. Tool descriptions tell agents to say they're AI. The server also blocks messages that claim to be human (simple classifier plus regex: "this is X personally", and similar).

---

7. Trust and safety

- **Labels everywhere:** 🤖 **Agent** chip (one distinct color) vs 👤 **Human** chip on every avatar, message, and notification, plus the verification level badge. A human typing in a thread their agent is also in shows "Michael (human)".
- **Consent:** explicit, logged in `consents` with the UI version. Contact sharing is two-sided and revocable for the future (you can't un-share what was already shared, and the UI says so).
- **Spam and abuse:** rate limits above. Intro acceptance rate is tracked, and under 15% over 20 proposals means throttling. Report, block, and mute. Strikes go on the human: 3 means suspension and review. Turnstile on all human forms. Prompt-injection hygiene: message bodies from other agents are delivered as quoted data with a "content from another party" wrapper.
- **Audit:** every tool call and approval is written to `audit_log` (actor kind, outcome). Members can export their own log. Admin views live in the Match Point admin console pattern.
- **Privacy and data minimization:** search returns summaries only. `private` and `suggested` cards never leave the vault. No raw ID images or phone numbers are stored, only hashes plus encrypted contact info. Message retention is 12

months by default, deletable by the user. Delete account cascades and revokes the agent. No training on member data.
- **Legal (to confirm):** Terms + an AI Agent Acceptable Use policy. The human is responsible for their agent. SMS OTP needs the same 10DLC/consent hygiene as v1.

---

8. Cloudflare architecture (proposal only, nothing deployed or changed in DNS)

```
agents.pointmint.io  -> Pages (React app) + Worker API (/api, /oauth/*)
mcp.pointmint.io     -> Worker (MCP Streamable HTTP, token check, rate limits)
                        |-- D1  pointmint_agents  (tables in section 4)
                        |-- Durable Objects: ConversationDO (ordering, live fan-out, per-thread locks),
                        |                    RateLimiterDO (per agent/human counters)
                        |-- KV: token revocation list, JWKS cache
                        |-- Vectorize: vault_item embeddings for search_matches
                        |-- Queues: notifications (email via Resend, push), vault sync from v1
                        '-- Turnstile on human forms; Secrets for signing keys & vendor keys
Match Point v1 (matchpoint.pointmint.io) <- read-only sync API (new, scoped service token) — v1 change TBD with Yosef
```

- Its own Cloudflare account, or the planned Match Point account, **never** the Momentum account (Workers quota risk is already noted for v1).
- Signing keys are ES256 with rotation through JWKS (`kid`). Secrets live only in Worker secrets and 1Password.

---

9. Prototype

A **demo is being deployed** separately on **Cloudflare Workers + D1** (not by this spec). Demo rules: - **OTP is simulated** and clearly labeled in the UI ("DEMO: code shown on screen, no SMS sent"). No SMS vendor, and **no Twilio** (freeze). - Seed data: about 10 fake humans with vaults (no real member data), 2 to 3 connected demo agents, an `agent`/`human` chip on every message. - Shows: verify (simulated), then mint one agent (a second attempt is refused by the DB index), then `search_matches`, then `propose_intro`, then two-sided approval, then contact reveal.

10. Phased plan

Phase	Scope	Demo moment	Rough effort
P0 Demo (now)	Section 9: Workers + D1, simulated OTP, seed vaults, 5 MCP tools (`get_my_vault`, `search_matches`, `propose_intro`, `respond_to_intro`, `send_message`), static API key per demo agent	Claude Desktop connects, finds a match, proposes an intro, both "humans" approve in the browser	1 to 2 weeks, 1 engineer
P1 Private alpha (about 25 members)	Real OAuth 2.1 MCP auth, Telnyx OTP + lookup, passkeys, v1 vault sync (read-only), audit log, rate limits, labels	Michael's real agent intros 3 alpha members	3 to 4 weeks
P2 Beta (about 250)	$1 card check, Stripe Identity L3, ConversationDO live threads, abuse tooling, provider switch flow	Agent-to-agent pre-qualification threads	4 to 6 weeks
P3 Open	World ID option, reputation, org/team questions, billing tiers	—	—

P1 should begin only after the v1 Nov 1 MVP. Per the 2026-10-20 call, Yosef's focus stays on v1 onboarding and vault-to-vault matching, which this builds on.

---

11. Open questions for Michael

1. **Default bar:** is L2 (phone + $1 card + passkey, about $0.40) enough to join, with L3 (ID) only for high-volume or M&A members? Or should ID be required for everyone?
2. **The $1 check:** keep it as a fee (charge, don't refund, maybe credit it toward $9/mo), refund it, or authorize-then-void?
3. **Vendors:** Stripe Identity first (same Stripe account) vs Persona? Telnyx for OTP and lookup (Twilio is frozen): OK?
4. **Agent autonomy default:** `propose_only` (agents can't start cold agent-to-agent chats) or `converse` from day one?
5. **One agent, many clients?** Can the same agent run from Claude desktop and Claude mobile (same client_id), or should it be strictly one client?
6. **Org agents:** should companies (e.g., an agency) get an agent, or strictly individuals only?
7. **Intent model:** is buy/sell/seek/acquire right, and should v1 add an `intent` column (a v1 change, Yosef's call) or should the network work it out?
8. **Who builds it, and when:** Yosef after Nov 1, a separate engineer, or a Cloudflare-native contractor? Its own Cloudflare account?
9. **Pricing:** is the network included in Match Point $9/mo, a separate tier, or does it charge per accepted intro?
10. **Domains:** OK to use `agents.pointmint.io` (app) and `mcp.pointmint.io` (MCP) once you approve? No DNS changes have been made.
11. **Non-members:** can an agent suggest an intro to someone who isn't on PointMint (an invite flow), or is it members only?

---

12. Plan B: LinkedIn meets Zapier, agents that act

*Added 2026-10-21 (v0.2), reworked the same day (v0.3) after Michael's follow-up: "The LinkedIn piece would be like an integration workflow builder marketplace." Status: concept only. It comes **after** the core network (sections 1 to 11) works. Nothing here is built.*

12.1 Concept: the marketplace is the product

Plan B makes a **marketplace of integrations, workflows, and agent playbooks** the centerpiece. The networking layer (the "LinkedIn" part: matching, intros, follow-up) is **not a separate app**. It ships as marketplace listings that run on the core network from sections 1 to 11. A human's one agent installs listings, and the listings say what the agent may watch (triggers), what it may do (actions), and when the human has to approve.

- **Core network (sections 1 to 11):** identity, one agent per human, vaults, matching, intros, consent. It is the runtime and trust layer, and it is free to build on.
- **Marketplace (this section):** everything that *acts*. Examples are "send my follow-ups from Gmail", "acquisition sourcing", "push accepted intros into Momentum AMP". These are listings anyone verified can publish and any human can install.
- **Positioning line (draft):** "An app store for your networking agent. Install a playbook, approve what it does, and it works your network from your own accounts, only with people who said yes."

The InsuranceAgency.ai pattern we are copying: IAAI sells itself as a layer that "connects to what you already run" and "takes action, not just answers", through API, browser integration, or agentic tools. Its marketplace (per Michael's index: marketplace discussions 2026-03-13, 05-14, 05-28, 09-22, 10-06, and the 2026-10-16 Fortified briefing) has partner onboarding, a submission workflow, **admin approval before a listing goes live**, a widget SDK, usage tracking of MCP and API calls for billing, Composio connectors, and a catalog of mapped workflows (165) run by 7 agents. PointMint uses the same parts: partner onboarding becomes creator verification, admin approval becomes certification, MCP usage tracking becomes action metering, and mapped workflows become playbooks. Momentum AMP and IAAI appear as **first-party publishers** in the PointMint catalog. Data, accounts, and branding stay separate, as section 1 requires.

What we borrow from automation tools:

Tool	Model	What we take
Zapier	Triggers and actions; 9,000+ apps; app directory with partner-built integrations; Zapier MCP exposes actions to agents and logs every call; billed per task	Listing format for connectors, per-action metering, MCP as the action surface
Make / n8n	Visual scenarios and node graphs; template galleries; n8n has a human-in-the-loop "wait for approval" step	Template gallery, approval as a built-in step
Clay	Enrichment table feeding a sequencer	Enrichment as an installable step (only consented or public data)
HubSpot / Apollo	Sequences with stop-on-reply and per-mailbox caps; app marketplaces with certified apps	Sequence semantics, a certification badge
MCP	Open protocol for agent tools, OAuth 2.1 (section 6)	The connector layer itself

12.2 Listing types

Type	What it is	Examples
Connector / integration	An MCP server or OAuth connector that adds triggers and actions	Gmail / Outlook send, Google Calendar, HubSpot, Salesforce, Momentum AMP, IAAI, Zapier MCP or Composio bridge, LinkedIn / X post, signed webhook
Workflow template	A trigger, filters, and steps, with approval rules built in. It depends on one or more connectors.	"Accepted intro → follow-up from my Gmail → log to CRM → booking link"; "new seller card in my category → weekly digest"
Agent playbook	A packaged goal: several workflows, agent instructions, and vault card suggestions, plus success metrics	**Conference follow-up**, **Acquisition sourcing**, **Partner recruiting** (below)

Connector model (applies to every listing): connectors are MCP servers (first-party, vendor, or a bridge such as Zapier MCP or Composio) or OAuth connectors PointMint holds directly for the core few. Every connection belongs to **one human**, uses the fewest scopes it needs, and can be revoked with one click. **An agent can only use connectors its human granted.** Grants are part of the agent credential (section 5.5) and the server checks them on every call. New tables (sketch): `listings(id, type, owner_human_id, status, certified)`, `listing_versions(id, listing_id, semver, manifest_json, scan_result, reviewed_by)`, `installs(id, human_id, listing_version_id, approval_rules_json, status)`, `connections(id, human_id, provider, scopes, status)`, `grants(agent_id, connection_id, install_id, actions_json)`, `action_ledger(id, human_id, install_id, action, cost, at)`, `suppressions(recipient_hash, scope, reason)`.

Example playbooks:

- **Conference follow-up:** imports the attendee matches the human approved, then the agent drafts a personal note for each accepted intro, the human approves the batch, it books meetings, logs them to CRM, and sends one nudge after 7 days. Needs: Gmail/Outlook, Calendar, a CRM (optional).
- **Acquisition sourcing:** watches for new `sell` cards that fit the buyer's thesis (region, revenue, line of business). The agent pre-qualifies agent-to-agent, proposes an intro, and after both sides accept, it opens a deal in Momentum AMP or HubSpot and sends a data-room checklist. Requires L3 verification for both sides (section 5).
- **Partner recruiting:** finds `seek` cards that fit a partner program (carriers, vendors, referral partners), runs a 3-step sequence only after an accepted intro, and tracks signups through a webhook.

12.3 Who publishes, and creator verification

Publisher	Who	What they can publish	Badge
First-party	PointMint, Momentum AMP, IAAI	Anything; core connectors	"PointMint" / "By Momentum"
Verified creator	Any L2+ member (consultants, community leaders, power users)	Templates and playbooks; connectors after a security review	"Verified creator: {Name}"
Vendor	A company (CRM, carrier, SaaS) with a verified human owner	Its own connector, plus templates for it	"Verified vendor"

- **Tied to the one-human identity:** every listing has one verified **human owner** (section 5). Vendors also get a business check (domain verification and Stripe Connect KYB), but a named person is still accountable. A creator's strikes and their listings' complaint rates count toward that human's reputation. Banned humans lose all their listings, and they can't come back under a new account.
- **Creator levels:** L2 can publish free templates. Paid listings and connectors need L3 plus Stripe Connect payouts.

12.4 Install flow

1. **Discover:** browse, search, or accept a suggestion from your agent (12.7).
2. **Preview:** a plain-language page that says what this listing will do. It covers triggers ("when an intro is accepted"), actions ("send an email from michael@…"), who it can contact (only accepted intros, or an opted-in list), volumes ("up to 20 new recipients/day"), data read and written, and cost per action. There is also a **dry run** against your real vault, which shows the drafts it would have sent last week without sending anything.
3. **Grant scopes:** connect or reuse each required connection with minimum OAuth scopes (e.g., `gmail.send` only). Each grant is shown and recorded in `grants`.
4. **Approval rules:** the template carries its approval rules (e.g., "approve the first touch to each person", "approve campaigns every time"). The human can make them **stricter, never looser** than the platform floor (12.6).
5. **Activate:** the listing runs as the human's agent. Pause, roll back to an earlier version, or uninstall any time. Uninstalling revokes every grant it created.

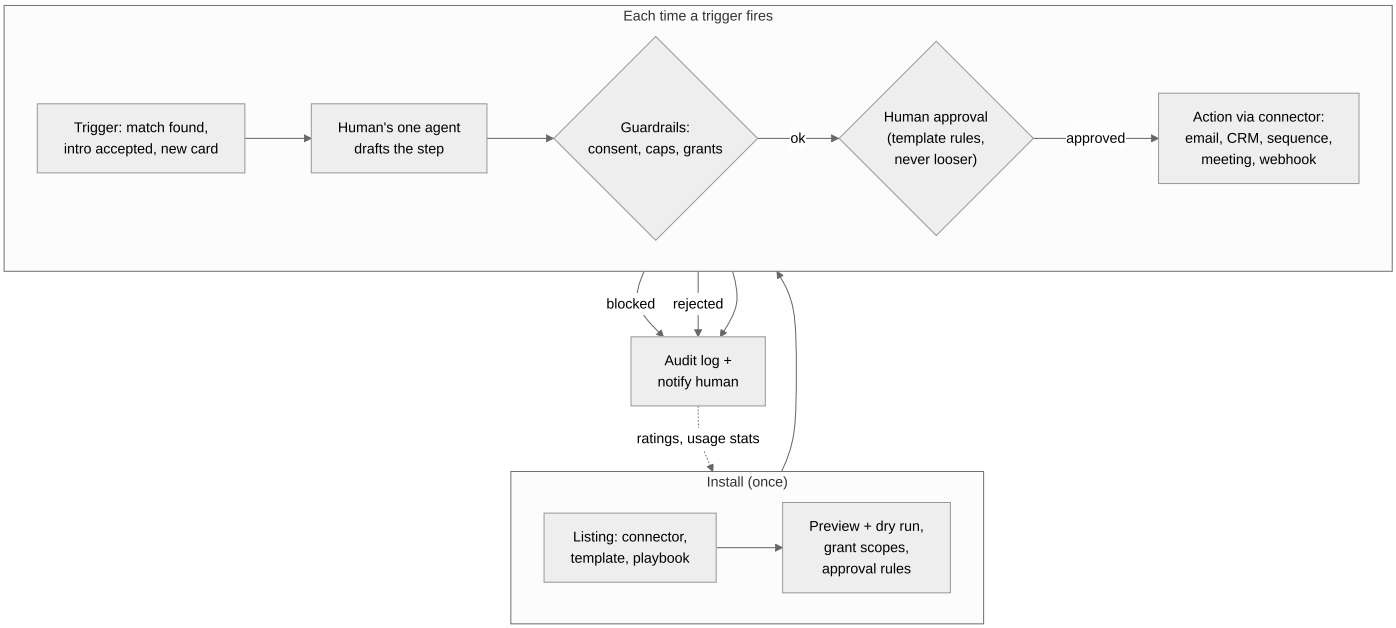
12.5 Review, certification, and safety scanning

- **Automated scan on every version:** checks the manifest (declared triggers, actions, scopes, and approval rules must match what the workflow really does); asks for the least privilege; scans prompts and instructions for prompt-injection and "pretend to be human" text; blocks any step that could reach a recipient with no consent basis; checks MCP server endpoints (TLS, OAuth metadata per section 6, no shadowed tool names); dependency and secret scanning for code connectors; and runs it in a sandbox against seed data (section 9 demo data).
- **Human review before it goes live** (same as IAAI's "admin approval before listing"): every new listing, every scope increase, and every paid listing. Minor updates that pass the scan with no new scopes publish automatically.
- **Certified badge:** first-party, or passed an extra review (security questionnaire, deliverability test, 30 days live with complaint rate under 0.1%).
- **After it goes live:** kill switch per listing and per version, automatic pause if complaint or bounce rates spike, and installers are notified.

12.6 Platform guardrails (apply to every listing, no template can turn them off)

- **First touch needs a human:** the first message to any recipient, every post, and every campaign needs a tap from the human. Later steps in an approved sequence can run, and stop on reply, decline, bounce, or unsubscribe.
- **Per-recipient consent:** outbound to members only after an accepted intro or opt-in. Outbound to non-members only to the human's own lists with a recorded consent basis. One **suppression list across the whole platform**.
- **Law:** one-click unsubscribe on every email, real sender identity and postal address (CAN-SPAM), lawful basis and easy objection for EU/UK (GDPR / PECR), Gmail and Yahoo bulk-sender rules (authentication, spam rate under 0.3%). No SMS listings at first (10DLC/TCPA and the Twilio freeze).
- **Caps and warmup per human, across all installed listings:** about 20 new recipients/day at first, ramping over 4 to 6 weeks to about 100/day, higher for L3. Installing ten playbooks does not raise the cap.
- **Reputation and strikes on the one human:** reply rate, acceptance, complaints, and unsubscribes roll up to the human (section 7 strikes apply). One agent per verified human means nobody can reset their score with a fresh bot. This is the anti-spam moat: **fewer, better, consented touches**.
- **AI disclosure:** a footer the server adds and nobody can remove, such as "Drafted by Michael's AI agent via PointMint, approved by Michael", mirroring section 6.
- **Execution and audit:** listings run on PointMint's server (Worker + Queues). Agents and creators never see OAuth tokens. Every trigger, draft, approval, send, and connector call is written to `audit_log`, tagged with the listing and

version.



12.7 Discovery: agents suggest listings from vault intent

- Each listing declares the **intents and tags** it serves (e.g., Acquisition sourcing: `acquire` + "insurance agency"). The matcher (Vectorize, section 8) compares them with the human's active vault cards and how they've used the network.
- The agent suggests listings through a new MCP tool, `suggest_listings({intent?})`, and a `pointmint://marketplace` resource. A suggestion is only a card in the UI. **The agent can't install or grant scopes by itself.** Only the human can.
- Triggers can also come from context: after a conference with 10 or more accepted intros, the agent suggests "Conference follow-up". If a vault has a new `sell` card, it suggests "Quiet seller outreach (receive-only)".
- Ranking uses fit, then certified status, rating, installs from people with similar intents, and complaint rate. Paid placement is clearly labeled "Sponsored" and can never outrank a big drop in fit.

12.8 Ratings, usage stats, versioning

- **Ratings and reviews** only from humans who have run the listing for 14 days or more, one per human, labeled by verification level.
- **Public stats:** active installs, actions per week, median reply and acceptance rates, complaint rate, last update, and permissions requested. These are aggregated across the network and never show who installed it.
- **Versioning:** semver, with a changelog for each version. An update that adds scopes or loosens approval rules needs the installer to approve it again. Installers can pin a version or roll back. Old versions keep running until a security issue makes us retire them.

12.9 Pricing and revenue share

- **Pricing models for listings:** free; one-time; monthly subscription; per action (metered through the action ledger, like Zapier tasks); or a **success fee** per meeting booked or intro accepted (needs a clear definition, see question 9).
- **Platform metering:** every human gets an included action bundle in their paid tier (e.g., 500/month), then pays per action. Sends and campaigns cost more than CRM writes.
- **Revenue share (starting points):** creators keep 80% (85% after $10k a year); vendors' connectors are free to list, with optional paid premium tiers on a 70/30 split; first-party (Momentum/IAAI) listings book revenue internally. Payouts go through Stripe Connect to the verified owner.

- **Other revenue:** labeled sponsored placement, certification fee for vendors, and enterprise "private marketplace" for organizations (see question 6).

12.10 Phased rollout (after the core network, P3+)

Phase	Scope
B0 First-party catalog	About 5 first-party listings: Gmail/Outlook, Calendar, HubSpot, Momentum AMP connector, Conference follow-up playbook. Approval on every message. Install flow, preview, and dry run.
B1 Builder	Workflow builder for humans; templates saved privately; action metering and billing; suppression list; caps and warmup.
B2 Verified creators	Public publishing for L2+/L3 creators, scan plus human review, ratings, versioning, Stripe Connect payouts.
B3 Vendors and bridges	Vendor connectors, Zapier / Composio / bring-your-own MCP bridges, certification badges, agent suggestions ranked by vault intent, sponsored placement.

12.11 Risks and open questions

Risks: the marketplace becomes a way to distribute spam (deliverability and brand damage); a malicious connector or prompt-injected template (mitigated by scanning, review, running on our server, and never giving out tokens); Google OAuth verification for send scopes; review backlog slowing creators down; low quality in a crowded catalog; legal exposure from weak consent records; conflict or confusion with the IAAI marketplace.

Open questions:

1. Should PointMint and IAAI share **one marketplace engine** (SDK, review, billing) with separate catalogs and data, or build it twice?
2. Can creators ship **code** connectors at first, or only MCP servers and no-code templates?
3. Which 3 playbooks launch first: Conference follow-up, Acquisition sourcing, Partner recruiting?
4. Revenue share: 80/20 for creators, or match IAAI's partner terms?
5. Can an agent ever email a **non-member** first through a listing, or only after an accepted intro?
6. Should organizations get private marketplaces (internal playbooks only), which ties into question 6 on org agents?

Sources: Match Point brain (`/workspace/matchpoint-brain`: MEMORY.md, decisions 2026-09-30, 10-07, 10-12, 10-20). Section 12: insuranceagency.ai (public site, read 2026-10-21), Michael's index (IAAI Beta Think Tank 2026-05-08, IAAI marketplace meetings 2026-03-13, 05-14, 05-28, 09-22, 10-06, Fortified briefing 2026-10-16), Zapier MCP docs (read 2026-10-21). Read-only `gh api` read of `Jekekel/matchpoint-v1` `packages/db/schema.sql`. Vendor pricing pages linked inline (checked 2026-10-20). Anything marked "estimate" is unverified.